Module 02: Reconnaissance

Introduction to Reconnaissance

Marcel Schnideritsch

What is Reconnaissance?

Definition

Systematically collecting information about a target **before** acting on it.

- First step of every attack
- Decides what the next steps look like
- Attackers do it. Defenders should too.

Information is power.

Passive vs. Active

Passive Reconnaissance

Zero packets to the target

Only public sources: search engines, job postings, DNS, certificates.

- Hard to detect, nothing in their logs
- Slow, data may be outdated
- Tools: `whois`, `dig`, theHarvester, Maltego

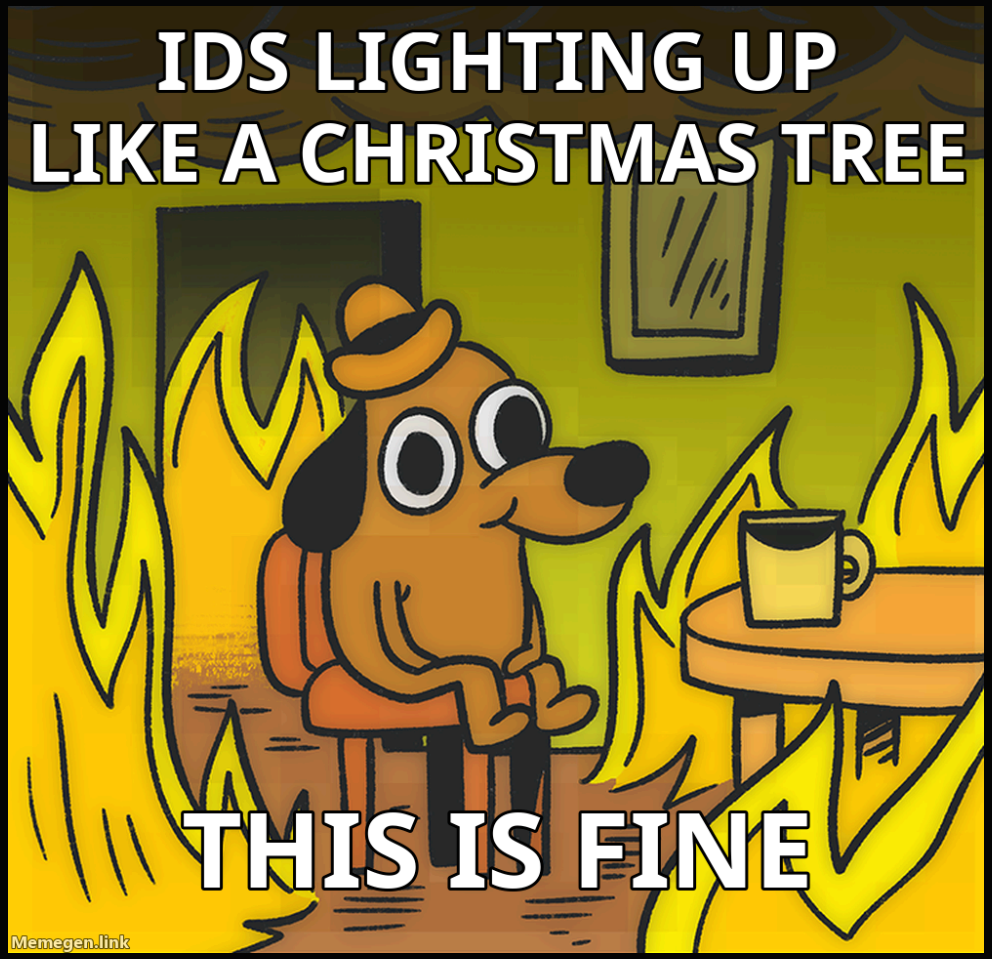

PORT SCANNING
THE TARGET
ON DAY ONE
READING THEIR
JOB POSTINGS FIRST
Memegen.link

Active Reconnaissance

Talk to the target directly

Scanning, banner grabbing, service and OS fingerprinting.

- Fast, accurate, current
- Leaves logs, triggers IDS/IPS
- **Needs written authorization**
- Tools: `nmap`, masscan, Nessus, Nikto


IDS LIGHTING UP
LIKE A CHRISTMAS TREE
THIS IS FINE
Memegen.link

Passive vs. Active

	Passive	**Active**
Detection	Very low	High
Accuracy	Historical	Current
Speed	Slow	Fast
Authorization	Rarely needed	Always needed

The Recon Process

Five Phases

1. **Information Gathering** – domains, IPs, people, tech stack
2. **Scanning** – live hosts, open ports, versions
3. **Enumeration** – users, shares, configs
4. **Vulnerability Mapping** – CVEs, misconfigurations
5. **Analysis** – attack paths, report

Each Phase Feeds the Next

> Job posting says “AWS + Terraform” → look at cloud assets
> Cert transparency shows `dev.example.com` → add to scope
> `nmap -sV` says Apache 2.4.49 → check the CVE database

Real-World Breaches

Recon Made These Possible

- **Target (2013):** attackers found the HVAC vendor, phished them, walked in
- **Equifax (2017):** fingerprinted an unpatched Apache Struts
- **SolarWinds (2020):** studied the build pipeline for months

The weakest link is often a supplier.

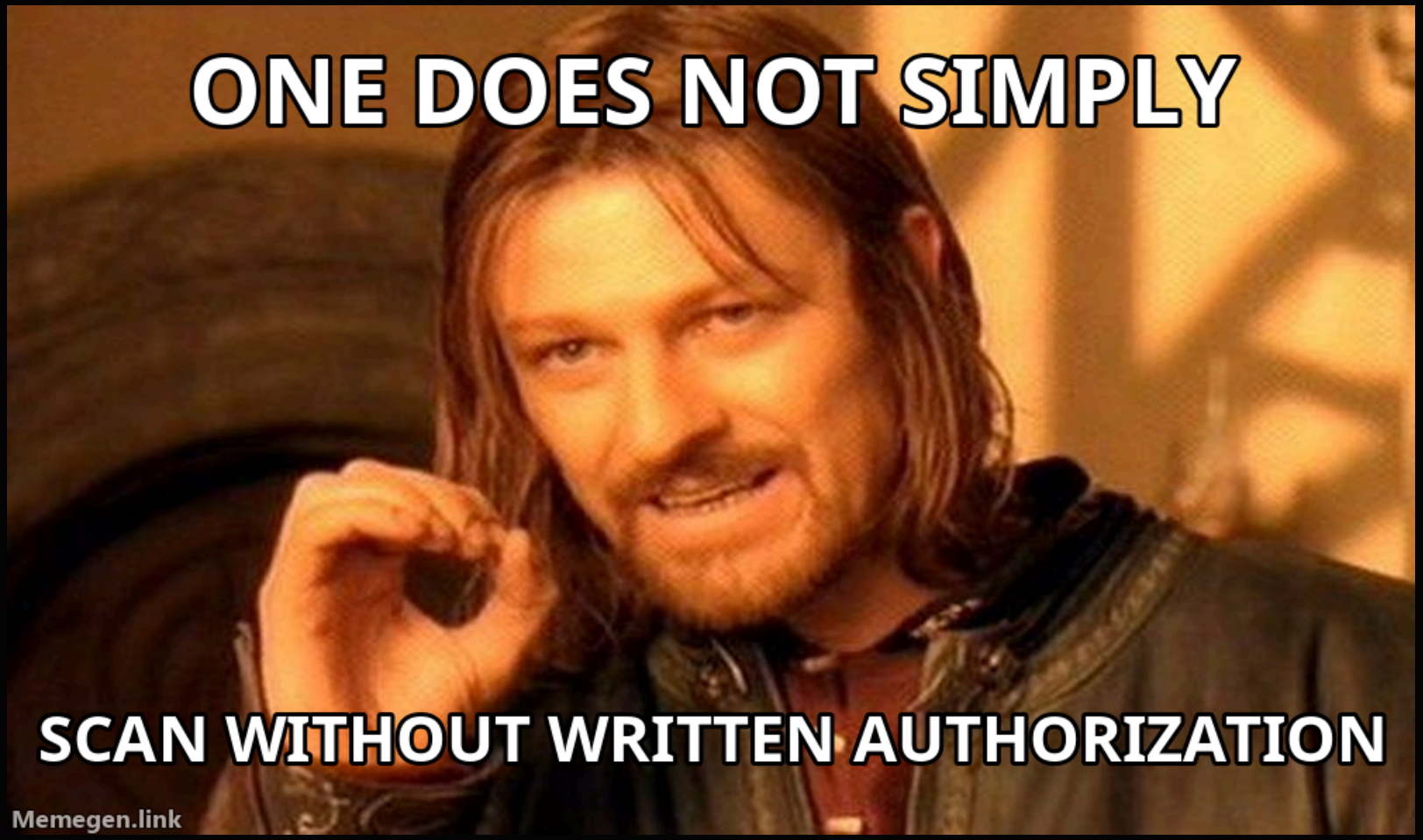
Rules

Authorization is Non-Negotiable

Written permission. Always.

Scope, IP ranges, time windows. Documented before you start.

- Unauthorized scanning is a crime (StGB §118a, CFAA, Computer Misuse Act)
- Even “passive” can cross the line
- Log everything you do, with timestamps


ONE DOES NOT SIMPLY
SCAN WITHOUT WRITTEN AUTHORIZATION
Memegen.link

Defending Against Recon

- Scan yourself before someone else does
- Strip version banners, minimize exposed services
- WHOIS privacy, CDNs, honeypots
- Detect it: rapid port sweeps, half-open SYNs from one IP

Takeaways

Remember

- Recon decides whether an attack works
- Passive = stealth, active = accuracy
- Authorization first, always
- Defenders: know what attackers can see

Resources

- nmap.org/book
- osintframework.com
- attack.mitre.org
- HackTheBox / TryHackMe

Module 02: Reconnaissance

Introduction to Reconnaissance

Marcel Schnideritsch